CloudDesk Technologies

Encryption and Key Management Policy

1. Purpose, scope and document authority

Document control

Policy ID: CD-ENC-001 | Version: 1.0 (wording revision). Proposed effective date: 2026-10-22; approval not recorded. Owner: Engineering Lead. Accountable approver: CTO. Review annually and after material architecture or cryptographic changes. Planned next review: 2027-10-22; approval not recorded. These are proposed dates, not an approved schedule.

Status and limits

SYNTHETIC / DEMO. This model-authored proposed policy is for CloudDesk, a fictional 75-person B2B SaaS company. It requires user review and does not show that controls are in use or effective. It is not human-approved evidence and makes no certification, external audit or legal compliance claim. Review_status: requires_user_review. Approval_status: not_recorded.

Scope

This policy covers employees, contractors and service identities handling customer data, credentials, production configuration or internal confidential information across the hosted SaaS service, supporting cloud infrastructure, corporate endpoints and backups. Public marketing content may be stored unencrypted; authentication and administrative traffic still need transport protection. Assess vendors handling this information against these requirements before use.

Related access requirements

Use unique user accounts and MFA for administrative access. Review user access permissions every quarter and revoke terminated employee access within 24 hours. Key permissions below add to these access requirements. Customer-managed keys and end-to-end encryption are not assumed capabilities.

Encryption and Key Management Policy

2. Encryption in transit and at rest

Transport protection

Use TLS 1.2 or TLS 1.3 for customer sessions, APIs, administrative consoles and service connections carrying scoped information, including database connections and internal service traffic. Disable SSL, TLS below 1.2 and plaintext fallbacks. Redirect public HTTP entry traffic to HTTPS; do not accept credentials or confidential request bodies over HTTP.

Certificates and validation

Clients must validate certificate trust, hostname and expiry without bypassing verification. Platform Engineering must maintain a certificate inventory with owners and expiry alerts at least 30 days before expiration. Renew certificates before expiry. Replace compromised certificate private keys immediately through incident response. Prefer managed issuance and renewal.

Stored information

Use AES-256 through managed cloud encryption for production databases, object storage, persistent volumes, snapshots and scoped log archives. Company laptops must use full-disk encryption through the supported operating system facility. Do not store scoped information on unencrypted removable media. Engineering must check encryption settings before provisioning production storage.

Application boundaries

Encryption at rest protects stored media; authorized application processes can still read plaintext. Keep credentials and private keys out of source code, application logs and support exports. Store service credentials in the approved secrets manager. Salt and hash passwords with a purpose-built password hashing scheme; do not reversibly encrypt them. Do not build custom cryptographic algorithms.

Encryption and Key Management Policy

3. Key storage, access and lifecycle

Key storage

Platform Engineering must use managed cloud KMS and envelope encryption for production keys. Key-encryption keys stay non-exportable in KMS. Store encrypted data keys with their encrypted objects when the service requires it. Keep application secrets and supported certificate private keys in a secrets manager. Separate production keys and grants from development and test.

Key access

Allow decrypt operations only for named workload identities and approved operators with a documented business need. Use least privilege and separate key administration from routine data access. Key administrators have no default decrypt permission. Engineering Lead approves grants. Human administrators use unique accounts and MFA. Review key grants every quarter and revoke terminated employee access within 24 hours.

Rotation

Rotate symmetric key-encryption keys at least every 12 months, using managed rotation where supported. New encryption uses the new active version. Keep restricted decrypt access to older versions only for data or backups still within retention. Rotation alone does not re-encrypt historical data. Platform Engineering must record the rotation date, version and outcome in the key inventory.

Compromise, revocation and destruction

For suspected key compromise, immediately open an incident, revoke affected identity grants and disable compromised versions where safe. Create replacement keys and assess re-encryption, affected data and backup recoverability. CTO must authorize temporary emergency decrypt access, with logging and next-business-day review. Destroy retired versions only after dependent data retention ends and recovery checks confirm no remaining need. Require Engineering Lead and CTO approval for destruction and record the evidence.

Encryption and Key Management Policy

4. Backups, exceptions and assurance

Backup encryption and recovery

Encrypt all production backups and snapshots at rest with AES-256 and transfers with TLS 1.2 or TLS 1.3. Use backup-specific key grants separate from ordinary application access.

Keep necessary older key versions for the full lifetime of retained backups, including legal or incident holds where applicable.

Test a representative encrypted restore at least quarterly. Record data integrity, authorized key access and the recovery outcome. This policy does not set backup schedules or retention periods.

Exceptions

Before deviating, the system owner submits a ticket with the affected data, reason, risk, compensating controls, owner and expiry date. Engineering Lead assesses it; CTO approves or rejects it.

Approvals expire within 90 days. Review monthly and close with remediation evidence. Renewals need a fresh assessment and approval.

Emergency deviations need an incident record and CTO review by the next business day. No active exceptions are asserted.

Responsibilities

CTO is accountable for risk acceptance and destructive key actions. Engineering Lead owns this policy and approves key grants. Platform Engineering implements encryption, certificate monitoring, rotation and restore checks.

System owners maintain inventories and fix deviations. All personnel promptly report suspected exposure through the incident process. Application teams keep plaintext secrets out of logs.

Evidence and review references

Expected evidence includes storage encryption configurations; TLS settings and certificate inventory; KMS key inventory, grant approvals and quarterly access reviews; rotation and destruction records; encrypted restore reports; exception tickets and incident records.

Review KMS administrative and decrypt audit events monthly and after incidents. Keep those KMS audit logs for at least 12 months in access-restricted encrypted storage.

These are proposed evidence types, not existing audit artifacts or test results. Review this policy annually and after material changes; record revisions and approvals before treating it as approved.